

Risk Management Dashboard — Formula Specification

COMPLETE — all 10 sections live: Register · Assessments · RCSA · Controls · Vendor · KRIs · Appetite · Mitigation · Reviews · Incidents — GET /erm/dashboard/sections-overview · 3 July 2026

Scoring Model

Each ERM page is a section scored by its own formulas over its own tables; every metric returns numerator n, denominator d, weight w, target (85) and its formula string. Achievement metrics: $(n/d) \times 100$, empty universe → excluded and weights re-normalize. Health metrics: $(1 - n/d) \times 100$, empty → 100. The module score re-normalizes over live sections while the module is built out. Risk score bands (L 1-5 × I 1-5): critical ≥ 20 , high ≥ 12 , medium ≥ 6 , low < 6 .

Section 1 — Risk Register (weight 18%)

Pages: /erm/risks list + register dashboard. Activities: create/edit/score/close risks, bulk upload, link assets/controls/evidence, treatment plans. Tables: grc_risks + risk link tables.

Metric	w	Formula	Live (demo)
Exposure containment	.25	1 - (active risks with residual ≥ 12 (high/critical) / scored active risks)	77.8 (2/9)
Risk reduction	.20	$(\Sigma \text{ inherent} - \Sigma \text{ residual}) / \Sigma \text{ inherent}$, over scored risks	33.1 (39/118)
Fully scored	.15	active risks with both inherent and residual scores / active risks	81.8 (9/11)
Ownership	.10	active risks with an assigned owner / active risks	81.8 (9/11)
Linked to context	.15	active risks linked to ≥ 1 asset / control / evidence / active risks	63.6 (7/11)
Treatment defined	.15	active risks with treatment plan or in treatment/mitigated/accepted / active risks	63.6 (7/11)

$S1 = 77.8(.25) + 33.1(.20) + 81.8(.15) + 81.8(.15) + 63.6(.15) + 63.6(.15) = 65.6$

Section 2 — Risk Assessments (weight 14%)

Pages: assessments dashboard/list/[id]/analytics, framework questionnaires (+ per-question evidence), AI risk assessment. Tables: grc_risk_assessments(+risks), grc_framework_risk_*, grc_ai_risk_assessment_entries.

Metric	w	Formula	Live (demo)
Assessments completed	.25	(manual approved/closed + framework completed) / all assessments	33.3 (1/3)
Question progress	.20	framework questions completed / all framework questions	66.7 (4/6)
Register coverage 12m	.20	distinct active risks assessed in last 12 months / active risks	72.7 (8/11)
Evidence-backed answers	.15	completed framework questions with ≥ 1 evidence file / completed questions	50.0 (2/4)
AI entries reviewed	.20	1 - (open AI entries past target review date / open AI entries)	50.0 (1/2)

$S2 = 33.3(.25) + 66.7(.20) + 72.7(.20) + 50(.15) + 50(.20) = 53.7$

Section 3 — RCSA (weight 9%)

Pages: RCSA dashboard, campaigns (create/activate/close/assign BUs), assessments (start/fill/submit), multi-tier approvals, findings, templates + custom templates. Tables: grc_rcsa_campaigns, grc_rcsa_assessments, grc_rcsa_responses(+evidence), grc_rcsa_findings.

Metric	w	Formula	Live (demo)
Assessments submitted	.25	submitted / under review / approved / all assessments in active+closed campaigns	66.7 (2/3)
Approved through pipeline	.20	assessments approved / assessments submitted into the approval pipeline	50.0 (1/2)
Findings resolved	.30	findings remediated / accepted / closed / all RCSA findings	50.0 (1/2)
Evidence-backed responses	.15	assessment responses with >= 1 evidence file / all responses	33.3 (2/6)
Submitted on time	.10	assessments submitted on/before campaign due date / submitted with dates	50.0 (1/2)

$$S3 = 66.7(.25)+50(.20)+50(.30)+33.3(.15)+50(.10) = 51.7$$

Section 4 — Internal Controls (weight 9%)

Pages: controls list (create/edit/bulk upload/AI-suggest) + detail tabs (testing, risks, escalations, framework mappings, approval workflow). Tables: grc_internal_controls, grc_internal_control_tests, grc_internal_control_risk_links.

Metric	w	Formula	Live (demo)
Active controls	.20	controls in active status / all internal controls	60.0 (3/5)
Tested	.25	active controls with >= 1 recorded test / active controls	66.7 (2/3)
Fully effective	.30	tested active controls with design AND operating effectiveness = effective / tested active	50.0 (1/2)
Linked to risks	.15	active controls linked to >= 1 risk / active controls	100 (3/3)
Test schedule kept	.10	1 - (active controls past next test date / active controls with a test schedule)	66.7 (1/3)

$$S4 = 60(.20)+66.7(.25)+50(.30)+100(.15)+66.7(.10) = 65.3$$

Section 5 — Vendor Risk / TPRA (weight 8%)

Pages: vendors list + 360 detail, 11-stage TPRA lifecycle (tiering/scoring engines, gates, checklists, RACI), findings + remediations + acceptances, monitoring signals, contracts + obligations, questionnaires, risk-360, board. Tables: grc_vendors, grc_vendor_assessments, grc_tpra_findings, grc_tpra_remediations, grc_tpra_monitoring_signals, grc_tpra_contracts, grc_tpra_control_obligations.

Metric	w	Formula	Live (demo)
Reassessments current	.20	1 - (active vendors past next reassessment date / active vendors with a date)	50.0 (1/2)
Vendors risk-scored	.15	active vendors with a residual risk score / active vendors	100 (2/2)
Assessments completed	.15	current (non-superseded) assessments completed or approved / current assessments	50.0 (1/2)
Findings closed	.20	TPRA findings closed or accepted / all TPRA findings	50.0 (1/2)
Remediations on time	.10	1 - (overdue remediations / open remediations)	0.0 (1/1)
Signals acknowledged	.10	monitoring signals acknowledged / all monitoring signals	50.0 (1/2)
Contract obligations met	.10	contract control obligations met or waived / all contract obligations	50.0 (1/2)

$$S5 = 50(.20)+100(.15)+50(.15)+50(.20)+0(.10)+50(.10)+50(.10) = 52.5$$

Section 6 — Key Risk Indicators (weight 9%)

Page: /erm/kris (create, measure, thresholds, AI-suggest). Tables: grc_risk_kris (+measurements).

Metric	w	Formula	Live (demo)
Signal health	.40	1 - (red KRIs / active KRIs); red = current value beyond amber threshold in the bad direction	75.0 (1/4)
Measured on schedule	.35	active KRIs measured within their frequency window (daily 2d / weekly 10d / monthly 35d / quarterly 100d / annually 380d) / active KRIs	75.0 (3/4)
High risks monitored	.25	active risks with residual >= 12 having >= 1 active KRI / active risks with residual >= 12	100 (2/2)

$$S6 = 75(.40)+75(.35)+100(.25) = 81.2$$

Section 7 — Risk Appetite (weight 9%)

Page: /erm/appetite (thresholds per category, breaches). Tables: grc_risk_appetite_config + grc_risks.

Metric	w	Formula	Live (demo)
Within appetite	.60	1 - (scored active risks above their category limit (tolerance, else max acceptable) / scored active risks in configured categories)	85.7 (1/7)
Categories configured	.40	risk categories with an appetite threshold / categories present in the register	57.1 (4/7)

$$S7 = 85.7(.60)+57.1(.40) = 74.3$$

Section 8 — Mitigation Actions (weight 10%)

Page: /erm/mitigation-actions (create, complete, link evidence). Tables: grc_risk_mitigation_actions (+evidence links). Replaces the page's old client-side array math.

Metric	w	Formula	Live (demo)
On schedule	.40	1 - (overdue mitigation actions / open mitigation actions)	66.7 (1/3)
Completed	.35	completed mitigation actions / all mitigation actions	40.0 (2/5)
Evidence-backed	.25	completed actions with linked evidence / completed actions	50.0 (1/2)

$$S8 = 66.7(.40)+40(.35)+50(.25) = 53.2$$

Section 9 — Risk Reviews (weight 9%)

Page: /erm/reviews (schedule, complete, skip). Tables: grc_risk_reviews.

Metric	w	Formula	Live (demo)
Schedule health	.40	1 - (overdue risk reviews / open scheduled reviews)	50.0 (1/2)
Register reviewed 12m	.35	distinct active risks reviewed in the last 12 months / active risks	18.2 (2/11)
Completed on time	.25	reviews completed on/before due date / completed reviews (12m)	50.0 (1/2)

$$S9 = 50(.40)+18.2(.35)+50(.25) = 38.9$$

Section 10 — Incidents (weight 5%)

Page: /erm/incidents (report, link risk, resolve, AI analysis). Tables: grc_risk_incidents.

Metric	w	Formula	Live (demo)
Resolved 12m	.40	incidents resolved or closed / incidents opened in the last 12 months	50.0 (2/4)
Critical contained	.35	1 - (open critical/high incidents / open incidents)	50.0 (1/2)
Linked to risks	.25	incidents linked to a register risk / all incidents	75.0 (3/4)

$S_{10} = 50(.40) + 50(.35) + 75(.25) = 56.2$

Module score — all 10 sections live (weights sum to 100%)

$P = 65.6 \times .18 + 53.7 \times .14 + 51.7 \times .09 + 65.3 \times .09 + 52.5 \times .08 + 81.2 \times .09 + 74.3 \times .09 + 53.2 \times .10 + 38.9 \times .09 + 56.2 \times .05 = 59.7 \rightarrow \text{fair}$

Attention queue: critical open risks + unscored risks + blocked questions + overdue AI reviews + open RCSA findings + overdue control tests + overdue vendor reassessments + open critical vendor findings + overdue vendor remediations + red KRIs + appetite breaches + overdue mitigation actions + overdue risk reviews + open critical/high incidents (live total: 14).

Depth audit — activity to metric

Page activity cluster	Metrics moved
Score / close / own / link / treat a risk	all six Register metrics
Approve assessment · answer questions · upload question evidence · AI review dates	all five Assessments metrics
Activate campaign · submit · tier-approve · remediate finding · evidence a response	all five RCSA metrics
Approve control · record test · keep test schedule · link risks	all five Controls metrics
Run engines · complete assessment · close findings · remediate on time · acknowledge signals · meet obligations · reassess on time	all seven Vendor metrics

Not counted — deliberate, on the record

- Advanced Analytics (heatmap, bow-tie, scenario, aggregation, KRI triggers): VERDICT — pure consumers/visualizers of register data; scenario runs are transient what-ifs. No formulas. Correctly excluded.
- RCSA maturity radar on the RCSA page is client-side improvised math (e.g. coverage = active_campaigns × 20) — flagged for replacement with these backend formulas at the graphical pass.
- RCSA custom templates (rows, promote-to-risk) — candidate: promoted rows ratio.
- RCSA delegation/return actions, per-tier aging, BU distribution — info stats / charts, not ratios.
- Vendor questionnaires (sent / submitted / reviewed) — candidate: response completeness rate.
- Vendor stage checklists, RACI staffing, gate decisions — candidates: checklist completion, stages with an Accountable, approval-with-conditions rate.
- Vendor SLA records (is_compliant) and vendor incidents — candidates for a monitoring metric.
- Controls: escalation rules, evidence links, framework mappings, workflow aging — info stats.
- Assessment enrichment (risks with linked KRIs/incidents), AI adoption/bridging — earlier candidates, still open.

Source of truth: backend/grc/modules/erm/routers/dashboard.py · demo data: backend/seed_demo_erm.py · markdown proposal: docs/risk-dashboard-formulas-proposal.md. ERM cards remain static by request; the graphical pass (a different chart family than governance) comes after all sections are live.